

1. CASE INFORMATION

FIELDS	DETAILS
Case Number	EHF-EXP09-STUXNET-07-10-2026
Investigator Name	Sergey Ulasen, VirusBlokAda, Ralph Langner
Discovery Date	17 June 2010
Case Subject	Stuxnet malware and the sabotage of industrial control systems associated with Iran's uranium enrichment programme
Principal Facility Examined	Natanz Fuel Enrichment Plant, Iran
Investigation Type	Retrospective digital forensic case study based on publicly available documentary evidence
Principal Incident Period	2009–2010, with earlier malware activity and subsequent research considered where relevant
Report Purpose	To document the evidence, investigation methodology, findings, chronology, limitations, and preventive measures associated with the case

Purpose and scope

This report examines the Stuxnet incident through the forensic phases of identification, preservation, collection, examination, analysis, and reporting. Its objectives are to explain the incident, identify relevant evidence, evaluate published technical findings, reconstruct significant events, and recommend measures to reduce the likelihood and impact of comparable attacks.

Administrative clarification

The academic case number above is not a police complaint number, court docket number, or government investigation identifier. The preparation date records when this report was compiled; it is not the date on which Stuxnet was discovered.

2. INCIDENT SUMMARY

Stuxnet was a malicious computer worm associated with a targeted industrial sabotage operation against Iran's uranium enrichment programme. Published technical research linked its industrial payload to the control arrangements used at the Natanz Fuel Enrichment Plant. The equipment of concern included Iranian IR-1 centrifuges and Siemens industrial control technology."

The investigation began with symptoms that initially resembled ordinary computer faults. In his account of the discovery, Sergey Ulasen described an Iranian customer experiencing repeated system crashes and unexpected reboots. Similar problems across several computers prompted further investigation, which identified malware with sophisticated concealment and propagation capabilities.

Stuxnet combined Windows infection mechanisms with functionality directed at industrial equipment. Its propagation methods included removable media, network mechanisms, and infected Siemens Step 7 project files. An infected computer could therefore act as an intermediate carrier without itself operating the intended industrial target.

Research identified distinct attack strategies across the malware's development. Later variants manipulated centrifuge drive speeds, while the earlier version known as Stuxnet 0.5 contained a valve-manipulation strategy. These differences matter because the behaviour of one variant cannot automatically be attributed to every Stuxnet infection.

The central forensic issue is the relationship between compromised computer systems, unauthorised controller changes, and reported physical disruption. Establishing that a computer contained Stuxnet is different from proving that a particular centrifuge failed because of its payload.

This report therefore separates documented malware capabilities, assessments of operational damage, and claims concerning responsibility. Each category requires a different evidential basis.

3. EVIDENCE COLLECTED

3.1 Documentary evidence reviewed

The following register identifies the documentary material reviewed for this case study. The identifiers E-01 to E-09 were assigned for organisation within this report. They are not original evidence labels from the historical investigation.

Evidence ID	Material reviewed	Investigative relevance
E-01	Symantec, <i>W32.Stuxnet Dossier</i> , version 1.4	Malware architecture, controller modification, infection statistics, and historical chronology
E-02	ESET, <i>Stuxnet Under the Microscope</i> , revision 1.1	Windows components, propagation, signed drivers, and technical indicators
E-03	Ralph Langner, <i>To Kill a Centrifuge</i>	Interpretation of industrial payloads and concealment mechanisms
E-04	Symantec, <i>Stuxnet 0.5: The Missing Link</i>	Earlier malware activity and differences between attack variants
E-05	Kaspersky, <i>Stuxnet: Zero Victims</i>	Reconstruction of early infections involving Iranian organisations
E-06	Microsoft security bulletins MS10-046, MS10-061, MS10-073, and MS10-092	Authoritative vulnerability identifiers and security-update dates
E-07	Institute for Science and International Security assessments published in December 2010 and February 2011	Evaluation of centrifuge disruption and limits on damage assessment
E-08	David E. Sanger's reporting on Operation Olympic Games, available through a reproduced excerpt	Reported state involvement, distinguished from technical proof
E-09	Published interview with Sergey Ulasen	First-person account of discovery and initial examination

4. INVESTIGATION METHODOLOGY

4.1 Step 1 — Study the case scenario

The supplied case presentation was reviewed to identify the incident, affected environment, alleged attack mechanisms, reported consequences, and proposed lessons.

The investigation was then organised around five questions:

1. What evidence supports deliberate industrial sabotage?
2. How could the malware reach and spread between relevant systems?
3. What changes did published analyses identify in computers and controllers?
4. What evidence connects those changes to operational disruption?
5. Which conclusions remain uncertain?

4.2 Step 2 — Identify digital evidence

Potential evidence was considered at three connected levels: the Windows environment, the industrial control environment, and the physical process.

This separation prevents a common analytical error: assuming that a finding at one level proves events at another. For example, a malicious driver on a workstation does not independently establish that the connected controller was modified or that a specific machine suffered damage.

4.3 Step 3 — Document evidence preservation

The preservation requirements were documented; original incident evidence was not available for preservation.

4.4 Step 4 — Document evidence collection

For this report, collection consisted of locating and reviewing the documentary sources listed in Section 3. Publisher identity, document version, publication date, and the relationship between each source and its claims were checked.

No live malware was executed. No affected endpoint, controller, or plant network was accessed. Disk imaging, memory acquisition, packet capture, and controller extraction were therefore not performed.

4.5 Step 5 — Examine the available evidence

The publications were examined for descriptions of propagation, operating-system vulnerabilities, malicious components, controller manipulation, and concealment.

Vulnerability identifiers and update dates were checked against Microsoft's own bulletins. Historical events were distinguished from the dates on which researchers later published their interpretations. Variant differences were also examined. In particular, descriptions of the earlier overpressure strategy were separated from descriptions of the later rotor-speed strategy. This prevented the report from combining different mechanisms into a single unsupported sequence.

4.6 Step 6 — Analyse the findings

The analysis compared technical capabilities with reported operational consequences. Three categories were used:

- **Published technical findings:** behaviours identified through researchers' examination of malware.
- **Supported assessments:** interpretations connecting those behaviours with the characteristics of the target environment.
- **Unresolved claims:** details that the reviewed evidence could not independently establish.

Alternative explanations were considered where appropriate. Mechanical failures, maintenance activity, and operational difficulties must be evaluated before attributing every equipment replacement to malware. Reported sponsorship was assessed separately from malware functionality. Technical sophistication alone does not identify an author, operator, or authorising government.

4.7 Step 7 — Reconstruct and validate the chronology

A chronology was prepared by separating malware activity, discovery, security updates, and later research publications. Dates were stated only to the precision supported by the sources. A compilation timestamp, discovery date, and publication date were not treated as interchangeable. A later publication about an earlier variant was recorded as a research event, rather than a new attack.

4.8 Step 8 — Prepare the forensic report

The report records what was reviewed, explains how conclusions were reached, and identifies evidential limitations. Recommendations are presented as proposed preventive measures, rather than as unverified claims about actions already implemented at Natanz. This approach supports transparency: a reader can distinguish source material, analytical interpretation, and outstanding evidence requirements.

5. FINDINGS

5.1 Deliberate manipulation of an industrial process

The reviewed technical research supports the assessment that Stuxnet contained functionality intended to interfere with a specific industrial process. Its targeting logic and process-dependent payload distinguish it from malware that merely causes incidental disruption.

Langner's analysis connected the payload to centrifuge operating conditions and control arrangements at Natanz. This supports a targeted-sabotage interpretation, while the exact physical outcome still requires operational evidence.

5.2 Multiple propagation routes and an incompletely established entry path

Kaspersky's reconstruction described early infections involving five organisations with a presence in Iran. This provides evidence of an infection network extending beyond the eventual industrial target. It does not independently establish every transfer that brought the malware into Natanz.

The evidence reviewed does not justify presenting a particular engineer, USB device, or handover event as the conclusively established entry point. Removable media was a documented propagation mechanism, but capability and historical proof of a specific introduction event are different matters.

5.3 Exploitation of Windows vulnerabilities

The Windows vulnerabilities associated with Stuxnet included weaknesses in shortcut handling, the Print Spooler service, kernel-mode processing, and Task Scheduler.

Microsoft bulletin	Relevant CVE	Affected component	Security-update release
MS10-046	CVE-2010-2568	Windows shortcut icon handling	2 August 2010
MS10-061	CVE-2010-2729	Print Spooler service	14 September 2010
MS10-073	CVE-2010-2743	Win32k keyboard-layout processing	12 October 2010
MS10-092	CVE-2010-3338	Task Scheduler	14 December 2010

5.4 Concealed Windows components and abused signing credentials

ESET documented components including mrxcsl.sys and mrxnet.sys, associated with code injection and file concealment. Published analysis also identified malicious drivers signed using certificates issued to Realtek and JMicron.

These findings demonstrate why a digital signature cannot, by itself, establish that a file is safe. The presence of a company's certificate on malware also does not establish that the company participated in the attack. The filenames are investigative leads, not sufficient identification criteria.

5.5 Controller modification and variant-specific concealment

Symantec documented Stuxnet's ability to modify controller code and interfere with how those changes appeared through the engineering interface. Consequently, examining a controller solely through a compromised workstation could produce misleading results.

Langner also identified an important distinction: recording and replaying process values formed part of the overpressure attack. The rotor-speed attack did not use that same mechanism. A description claiming that every Stuxnet variant changed centrifuge speeds while replaying normal sensor readings would therefore be inaccurate.

5.6 Infection extended beyond the intended industrial target

Symantec reported approximately 100,000 infected hosts by 29 September 2010, with roughly 60% in Iran. These observations were based on the visibility available through its monitoring.

5.7 Physical disruption is supported, but precise damage remains qualified

The Institute for Science and International Security reported that approximately 1,000 IR-1 centrifuges were decommissioned and replaced in late 2009 or early 2010. Its initial assessment considered Stuxnet a possible explanation while acknowledging uncertainty concerning overall effects.

Its February 2011 update strengthened the assessment linking Stuxnet to centrifuge damage, but also explained that Iran's enrichment programme and accumulation of low-enriched uranium continued.

5.8 Reported state responsibility is distinct from technical attribution

David E. Sanger's reporting attributed Operation Olympic Games to a joint United States–Israeli effort, drawing on interviews with officials and participants whose identities were not publicly disclosed.

6. TIMELINE OF EVENTS

DATE OR PERIOD	EVENT
November 2007	A Stuxnet 0.5 sample was submitted to a public malware-scanning service, as subsequently identified by Symantec.
June 2009	The documented development history includes the later Stuxnet 1.001 variant.
Late 2009–early 2010	Approximately 1,000 IR-1 centrifuges were reportedly decommissioned and replaced at Natanz; later assessments examined a possible Stuxnet connection.
17 June 2010	Published technical timelines date VirusBlokAda's detection of Stuxnet components to this day.
2 August 2010	Microsoft released MS10-046 for the shortcut-handling vulnerability.
14 September 2010	Microsoft released MS10-061 for the Print Spooler vulnerability.
12 October 2010	Microsoft released MS10-073, addressing the relevant kernel-mode vulnerability.
14 December 2010	Microsoft released MS10-092 for the Task Scheduler vulnerability.
22 December 2010	The Institute for Science and International Security published its preliminary centrifuge-damage assessment.
February 2011	Symantec published version 1.4 of its Stuxnet dossier.
16 February 2011	The Institute published an updated assessment of the malware's effect on Natanz.
1 June 2012	Sanger's reporting publicly described the alleged United States–Israeli Operation Olympic Games programme.
26 February 2013	Symantec published its analysis of Stuxnet 0.5, extending the documented history of the malware.
November 2013	Langner published a detailed analysis of the industrial attack mechanisms.
11 November 2014	Kaspersky published its reconstruction of early organisational infections.

7. Conclusion

The reviewed evidence supports the conclusion that Stuxnet was designed for targeted industrial sabotage. Published analyses describe malware that combined computer compromise with unauthorised changes to industrial control behaviour.

The association with Natanz is supported by the relationship between the payload's characteristics and the centrifuge-control environment described in specialist research. Assessments of equipment disruption provide additional support, although the exact extent of damage cannot be independently quantified from the material available for this report.

The case demonstrates why industrial forensic investigations must connect evidence from computers, engineering software, controllers, and the physical process. An endpoint infection does not alone prove mechanical damage. Equally, apparently normal information from a compromised interface cannot establish that the underlying process remained unaffected.

The academic investigation fulfilled the reporting objective by identifying relevant evidence, documenting the method of review, distinguishing findings from inference, and reconstructing a supported chronology. Its limitations remain explicit: original incident artefacts were unavailable, independent laboratory verification was not performed, and responsibility was not judicially determined by this examination.

The principal forensic lesson is that a defensible report must state both what the evidence supports and what additional evidence is required.

8. RECOMMENDATIONS

1. Control removable media

Permit only authorised removable devices and approved transfer procedures. Inspect incoming engineering files and maintenance media before their use within sensitive operational environments.

2. Restrict communication between systems

Separate business networks, engineering workstations, and control systems. Permit only necessary communications and subject maintenance connections to documented approval and monitoring.

3. Maintain controlled security updates

Inventory operating systems and industrial software. Test applicable updates before deployment, and document compensating controls where operational constraints prevent immediate installation.

4. Limit administrative and engineering privileges

Restrict controller programming and workstation administration to authorised personnel. Use individual accounts and retain records of approved configuration changes. These controls are consistent with the operational technology protections discussed in NIST SP 800-82 Revision 3.

5. Verify controller changes independently

Maintain protected reference copies of approved controller programmes. Investigate unexpected differences using trusted equipment, rather than relying exclusively on the workstation through which a suspected compromise occurred.

6. Preserve evidence before remediation

Document system conditions and retain relevant logs, images, and configuration records before rebuilding systems, where safe. Record collection methods, integrity checks, custody transfers, and unavoidable changes.

7. Practise coordinated recovery

Exercise incident response with security staff, control engineers, plant operators, and management. Test restoration of both computing systems and approved control logic, including confirmation that the physical process operates safely.

The immediate priorities are to restrict uncontrolled transfers, protect engineering access, and establish trustworthy configuration baselines. Longer-term improvement should strengthen monitoring, evidence retention, and coordinated recovery.